



Gregor Reimling
Thomas Naunheim

Azure Governance Best Practices and Enterprise-Scale Start 15:25



SquaredUp



infinity



kpn
Partner Network



INS PARK



cegeka



Cloud Consultant
@adesso SE

Gregor
Reimling



SquaredUp



infinity



INTERSTELLAR



kpn
Partner Network



INS PARK



cegeka



Cyber Security Architect
@glueckkanja AG



Thomas
Naunheim



SquaredUp



infinity



INTERSTELLAR



kpn
Partner Network



INS PARK



cegeka



What are we going to discuss?

1. Challenges & Best Practices in Azure Architecture
2. Overview of Enterprise Scale & Landing Zones
3. Govern & Secure workloads with Policy and MDC
4. Critical design areas in Identity & Access



1. Challenges & Best Practices in Azure Architecture

„Quick start“ in Cloud Adoption





Biggest challenge in your project(s)?

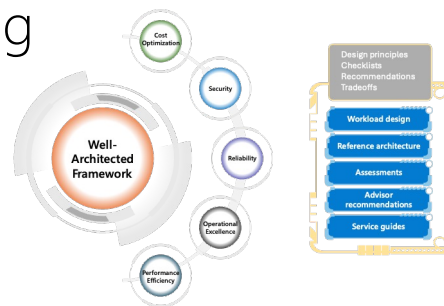
- lack of knowledge and insufficient time
- low degree of automation
- Regulatory/Compliance vs. Agile
- Cost transparency
- Considerations in security and data privacy
- ...

Azure Cloud Adoption Framework (CAF)

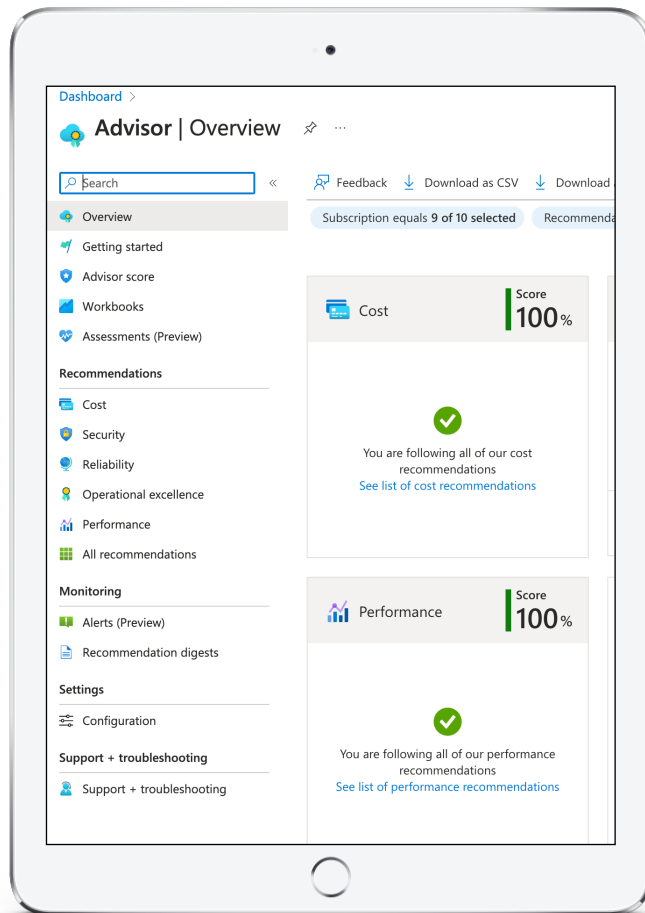
„The Cloud Adoption Framework is a collection of documentation, implementation guidance, best practices, and tools that are proven guidance from Microsoft designed to accelerate your cloud adoption journey.“

Azure Well-Architected Framework (WAF)

“The Azure Well-Architected Framework is a set of guiding tenets that can be used to improve the quality of a workload.”



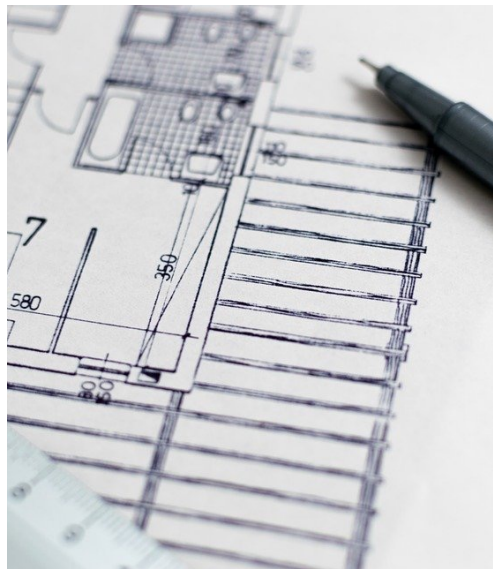
Demo + Azure Advisor & FinOps





2. Overview of Enterprise Scale & Landing Zones

Environment for your cloud workloads



SquaredUp



infinity



INTERSTELLAR



kpn
Partner Network



INS PARK



cegeka

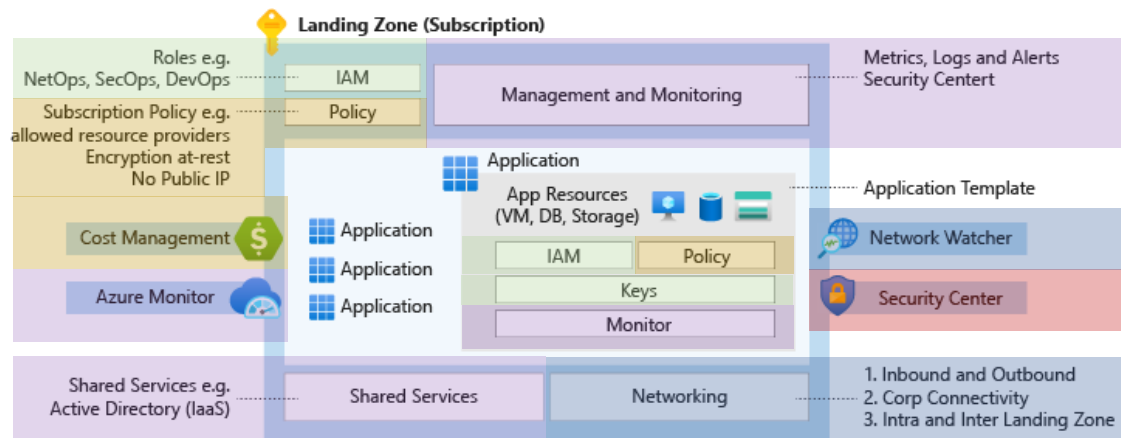


What is Enterprise-Scale?

„Azure landing zones help customers **set up their Azure environment** for scale, security, governance, networking, and identity.“

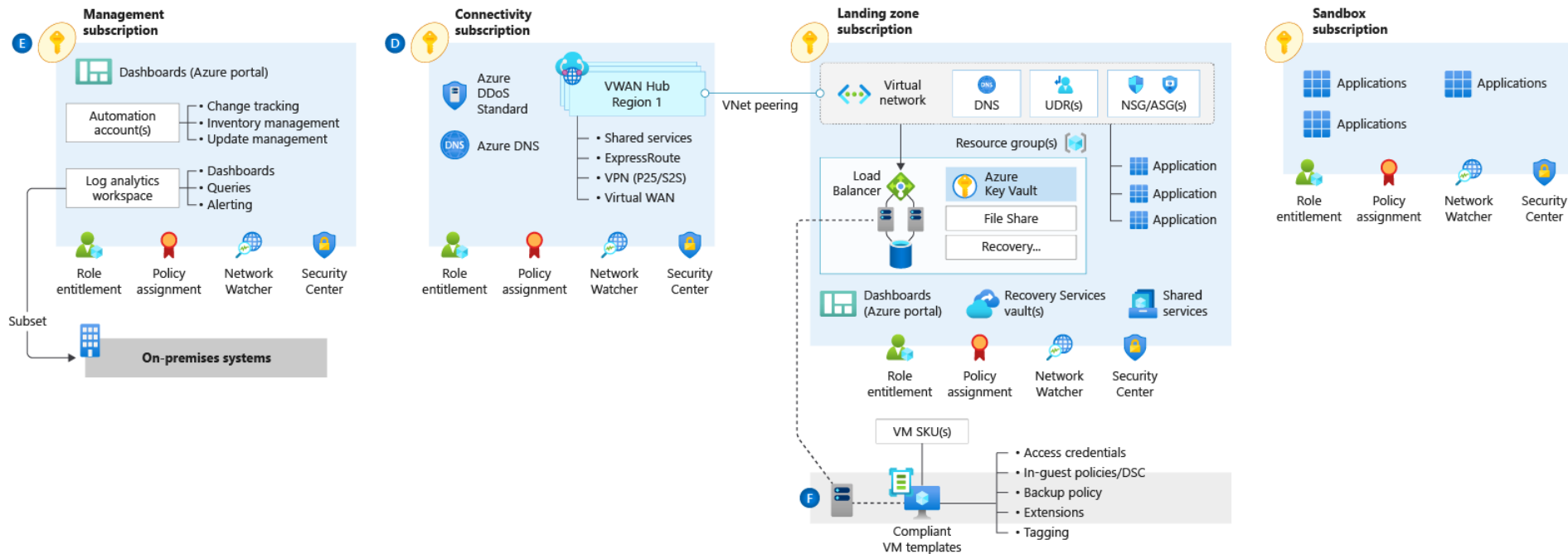
„Draw on Microsoft’s proven technical guidance, resources, and templates, to guide your customers through iteration and learning as they gain confidence and successfully adopt Azure.“

Design areas of Landing Zone(s)



Connectivity, Identity, Governance, Operations
and Security

Enterprise-Scale Design Principles



SquaredUp



infinity



kpn
Partner Network

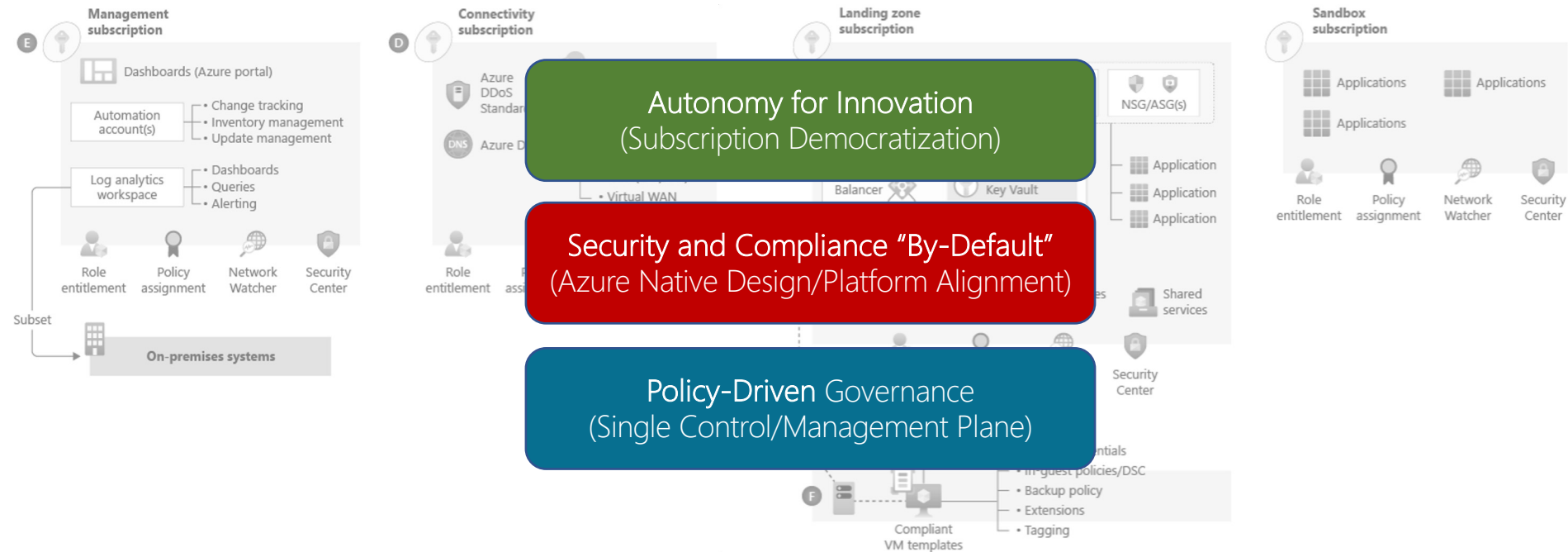


INS PARK



cegeka

Enterprise-Scale Design Principles



SquaredUp



kpn
Partner Network



INS PARK



cegeka

Demo + Deploy and manage EAS/ELS2

Dashboard >

Azure landing zone accelerator

Deploy from a custom template

Deployment settings Azure core setup Platform management, security, and governance Ba

Template

 Customized template  124 resources

[Edit template](#) [Edit parameters](#)

Select cloud environment

Azure cloud environment ⓘ

 This value should be automatically set based on the list of available locations. Only change this if you believe the value to be incorrect.

Project details

Deploying templates at the directory (tenant) scope enables scenarios like applying policies and assigning roles to the Microsoft Entra ID tenant you are currently logged into. You can change the deployment scope by updating the schema in the deployment template.

Directory *

CloudLab
cloud-architekt.net

 You don't have authorization to perform action 'Microsoft.Resources/deployments/validate/action'.

 Switching directories will result in the Azure portal being reloaded. Any progress will be lost.

Instance details

Region * ⓘ

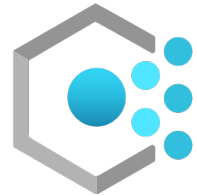
[Previous](#) [Next](#) [Review + create](#)



3. Govern and Secure your workloads with Azure Policy and Defender for Cloud



Azure Policy Concepts

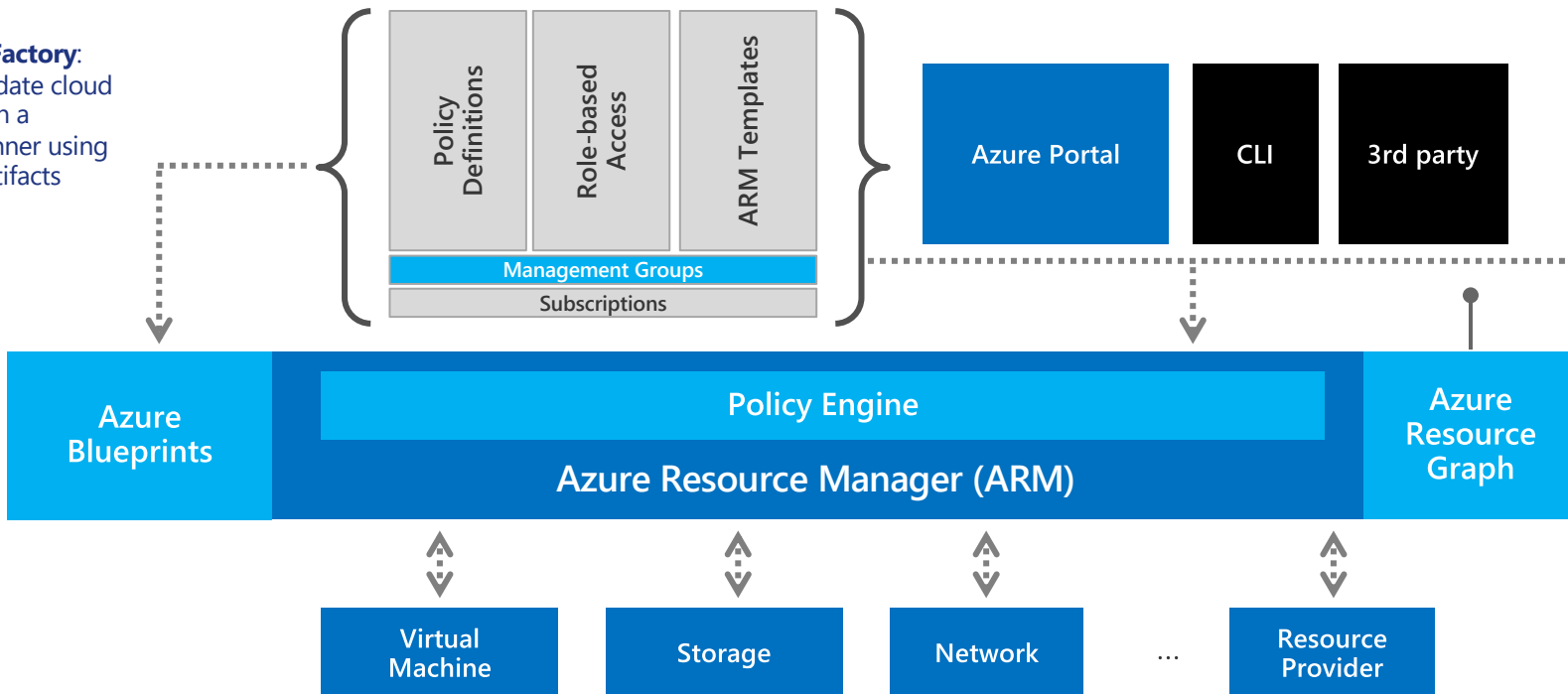


- Part of CAF to support WAF
- Create, assign and manage policies
- Enforce rules to ensure your resources are compliant
- Focus on resource properties for new and existing deployments
- A definition is a set of conditions in audit or deny mode
- An assignment is a policy definition placed on a specific scope
- An initiative is a collection of policies

Azure Governance Architecture

Environment Factory:

Deploy and update cloud environments in a repeatable manner using composable artifacts



Leverage built-in initiative & policies



Security

Defender for Cloud
Guest Config baselines
Key Vault certificate
NSG rules
AKS & AKS Engine
RBAC role assignment



Regulatory Compliance

NIST SP 800-53 R4
ISO 27001:2013
CIS
PCI v3.2.1:2018
FedRAMP Moderate
Canada Federal PBMM
SWIFT CSP-CSCF v2020
UK Official and UK NHS
IRS 1075



Tags

Require specified tag
Add or replace a tag
Inherit a tag from the RG
Append a tag



Resource standardization

Allowed/ not allowed RP
Allowed locations
Naming convention
Back up VMs
Allowed images for AKS



Cost

Allowed VM SKUs
Allowed Storage SKUs



SquaredUp



infinity



INTERSTELLAR



kpn
Partner Network



INS PARK



cegeka

Microsoft Defender for Cloud

Strengthen and manage your security posture



Security compliance management



At-scale governance & automated remediation



Attack path-based prioritization



Full visibility with agentless and agent-based scanning



Amazon Web Services



Microsoft Azure



Google Cloud Platform



On-premises



SquaredUp



infinity



INTERSTELLAR



kpn
Partner Network



INS PARK



cegeka



How it works together with Azure Policy

- All MDC recommendations based on Azure Policy
- Secure score is result of Azure Policy settings
- Recommendations are a result of Azure Policy
- All Azure Policies are defined in Compliance mode



SquaredUp



infinity



INTERSTELLAR



kpn
Partner Network



INS PARK



cegeka

Assign recommendations to LZ Owner

Dashboard >

Governance rules ...

+ Create governance rule

Refresh

Enable

Disable

Delete

Governance report

Guides & Feedback

Defender CSPM for GCP was released to General Availability! [Learn more >](#)

Search by name

Scope : All

Add filter

☐	Rule name	Rule type	Environment	Scope
☐	Notify owner by high and medium recomme...	Defender for Cloud	Azure	Platform
☐	Notify owner by medium or high recommend...	Defender for Cloud	Azure	Platform

Create governance rule

General details

2 Conditions

Impacted recommendations *

☒ By severity

High

☐ By specific recommendations

Select

Set owner

Owner *

By resource tag

Specify tag key *

owner

Set remediation timeframe

Remediation timeframe *

7 days

☒ Apply grace period ⓘ

Set email notifications

☒ Notify owners weekly about open and overdue tasks

☒ Notify owner's direct manager weekly about open and overdue tasks

Email configuration day of week *

Monday

ⓘ A weekly email will be sent to specified owners and their managers with all recommendations they are assigned to.

geka

Microsoft Defender for Cloud

Strengthen and manage your security posture



Security compliance management



At-scale governance & automated remediation



Attack path-based prioritization



Full visibility with agentless and agent-based scanning

Unify your DevOps security management



DevOps posture visibility across pipelines



Infrastructure as Code security



Code to cloud contextualization



Integrated workflows & pull request annotations



Amazon Web Services



Microsoft Azure



Google Cloud Platform



On-premises



SquaredUp



infinity



INTERSTELLAR



kpn
Partner Network

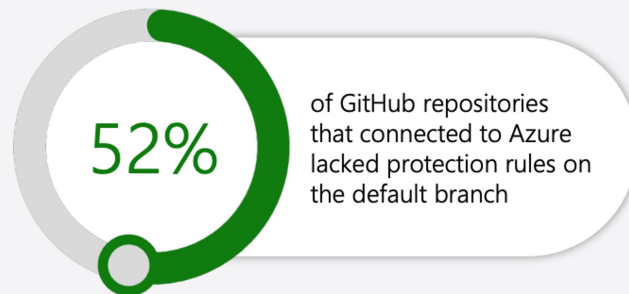
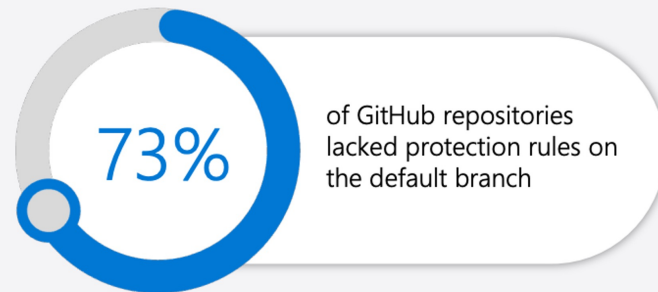
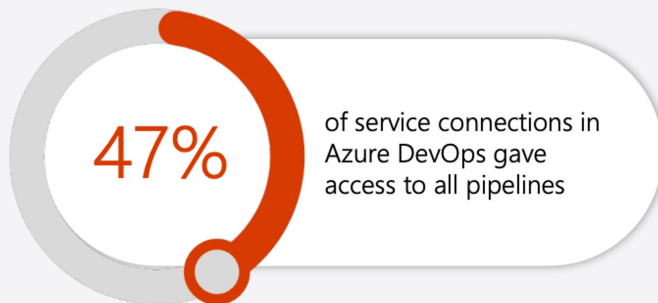


INS PARK



cegeka

Why DevOps Security is important?



SquaredUp



infinity



INTERSTELLAR



kpn
Partner Network



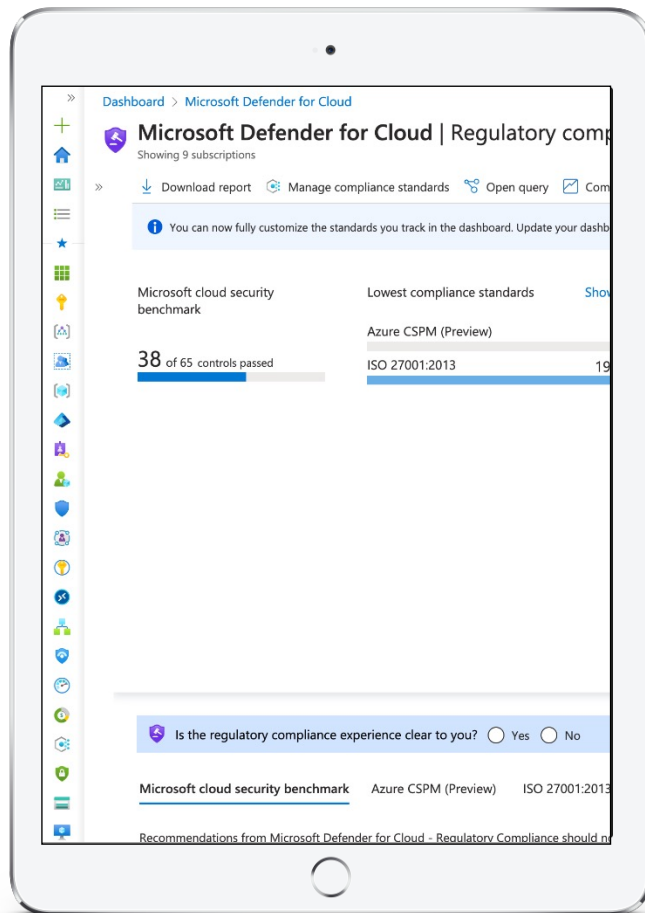
INS PARK



cegeka

Demo

Policy and Defender for Cloud CSPM



Microsoft Defender for Cloud

Strengthen and manage your security posture



Security compliance management



At-scale governance & automated remediation



Attack path-based prioritization



Full visibility with agentless and agent-based scanning

Unify your DevOps security management



DevOps posture visibility across pipelines



Infrastructure as Code security



Code to cloud contextualization



Integrated workflows & pull request annotations

Detect threats and protect your workloads



Full-stack threat protection



Vulnerability assessment & management



Automate with the tools of your choice and native integration in Microsoft Sentinel



Amazon Web Services



Microsoft Azure



Google Cloud Platform



On-premises



SquaredUp



infinity



INTERSTELLAR



kpn
Partner Network

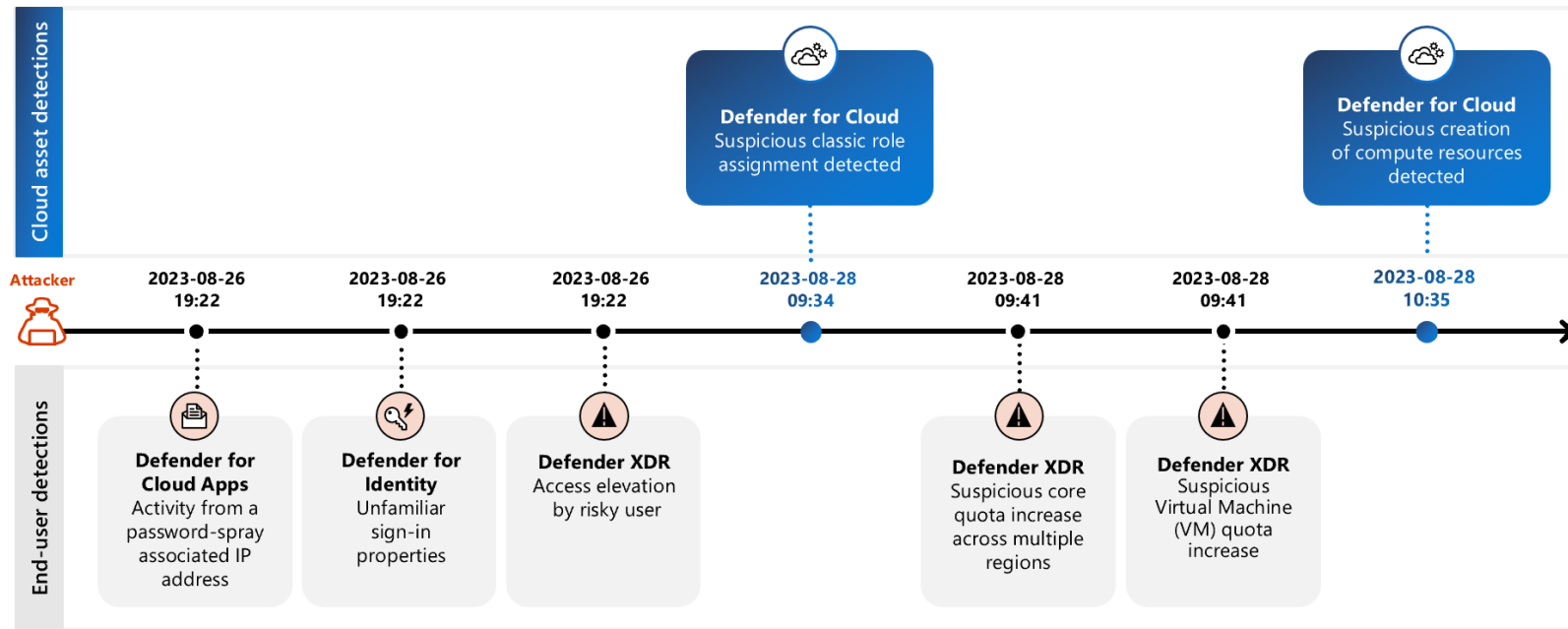


INS PARK



cegeka

Multi-stage attacks on Azure privileges



Multi-stage incidents XDR + MDC

Medium Active Unassigned

Attack story Alerts (3) Assets (7) Investigations (0) Evidence and Response (2) Summary

Alerts

Play attack story Unpin all Show all

- Jan 5, 2024 7:48 AM New
MicroBurst exploitation toolkit used to extract keys to your storage accounts
4 Cloud Resources
- Jan 5, 2024 7:48 AM New
Unusual ISP for an OAuth App
- Jan 5, 2024 7:56 AM New
Suspicious Azure role assignment detected (Preview)
32186319-59a7-415a-9736-9bb17cf80bcf

Incident graph

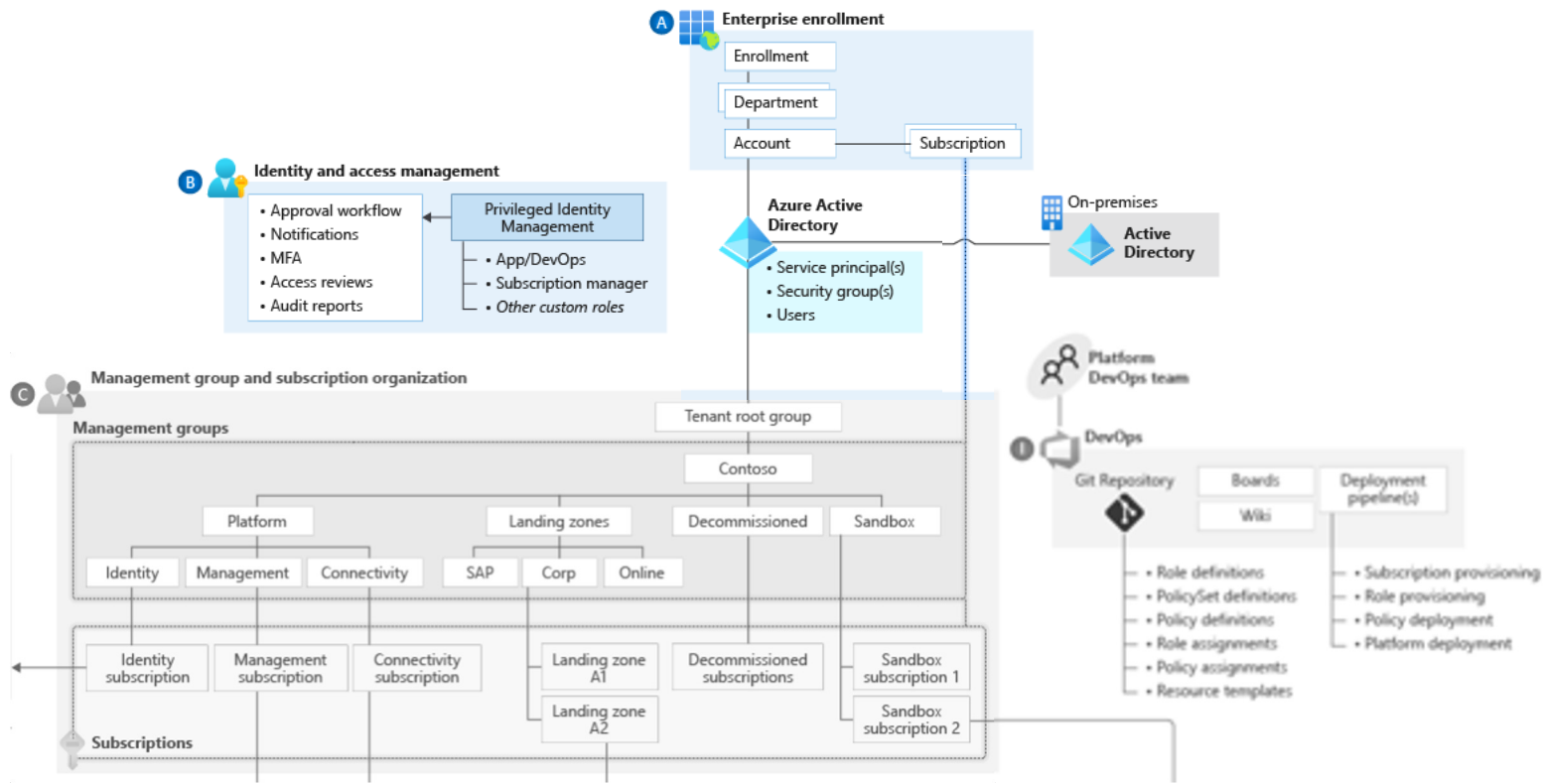
Layout Group similar nodes

— Communication Association



4. Critical design areas in Identity & Access Management

Critical Design Area: Identity & Access



SquaredUp



infinity



INTERSTELLAR



kpn
Partner Network



INS PARK



cegeka



IAM for Azure Landing Zones

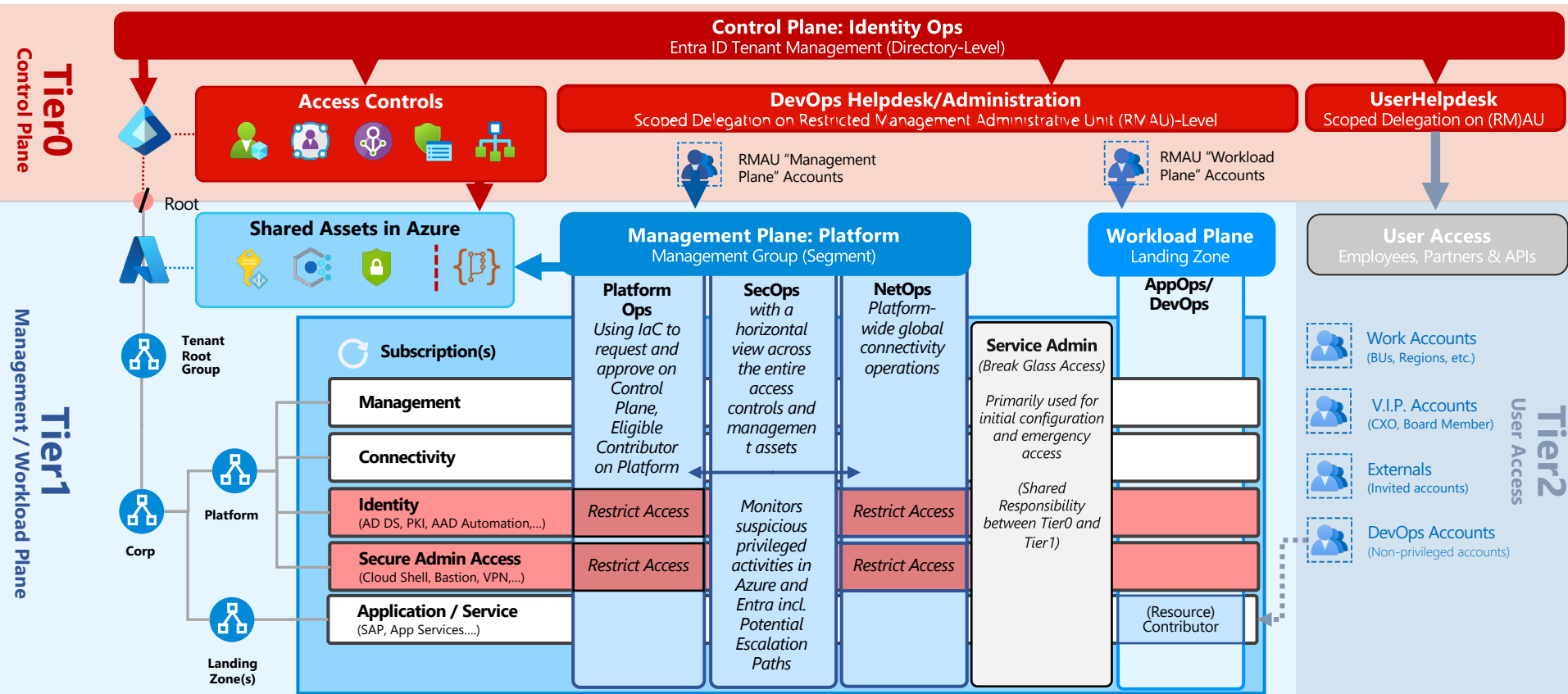
„IAM supports the ALZ design principle of subscription democratization“

„we trust application owners to know what's best for their apps“

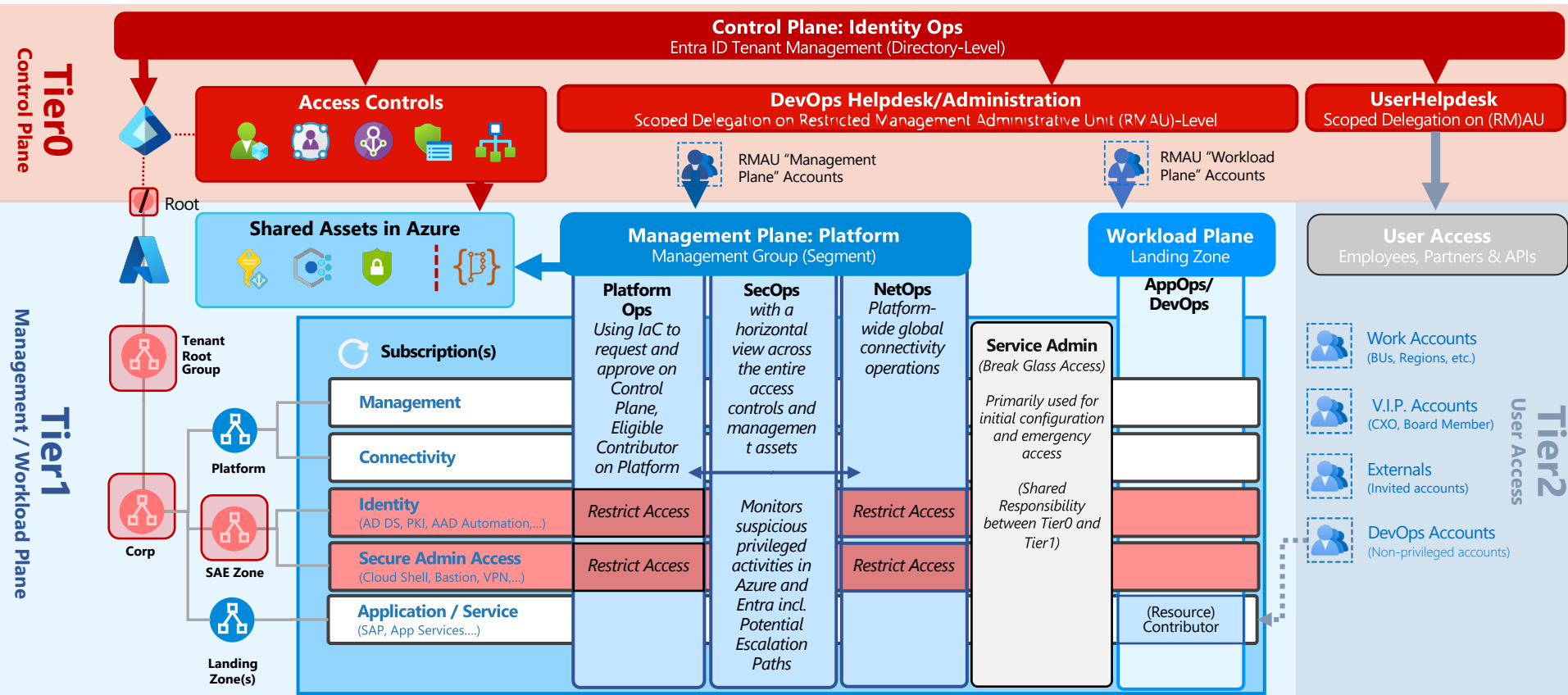
„we separate the identity and access management of every environment and every workload and avoid global permissions or reused credentials.“

Source: [Refreshed Identity and Access Management CAF documentation \(microsoft.com\)](https://docs.microsoft.com/en-us/azure/active-directory/refreshed-identity-and-access-management-caf)

My Adoption of Enterprise Access Model



My Adoption of Enterprise Access Model



Example for Azure Policies related to IAM governance



- RBAC assignment only allowed for specific principals on Control Plane
- Audit usage of custom RBAC roles



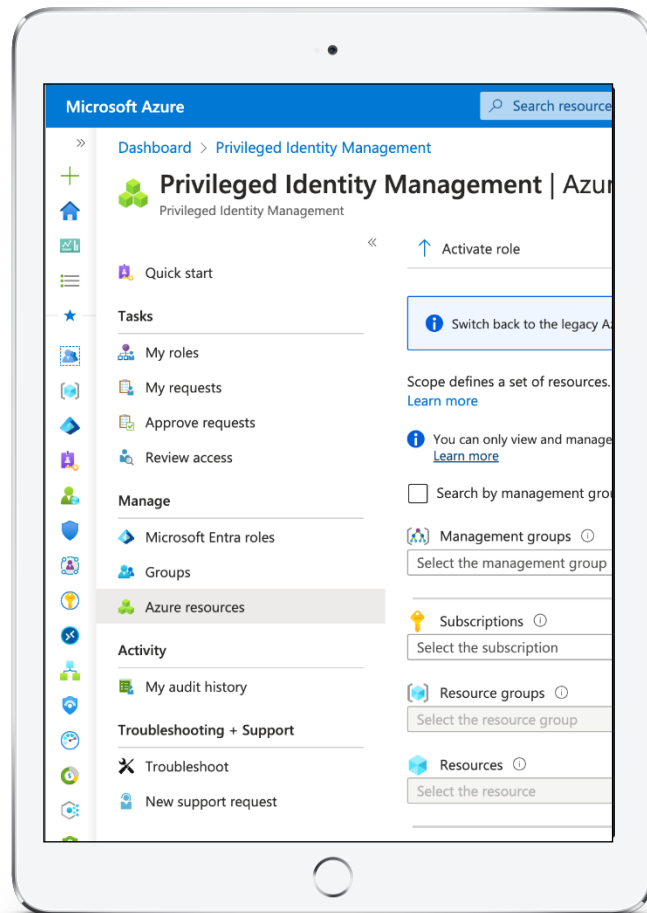
- Allow managing tenant ids to onboard through Azure Lighthouse
- Audit delegation of scopes to a managing tenant



- [Preview]: Managed Identity Federated Credentials from GitHub should be from trusted repository owners
- [Preview]: Managed Identity Federated Credentials from Azure Kubernetes should be from trusted sources
- [Preview]: Managed Identity Federated Credentials should be from allowed issuer types

Demo

Protect and delegate privileges





Please evaluate this session in the App.

THANK YOU

Are there any questions?

